DATA ITEM DESCRIPTION

Title: SOFTWARE ATTACK SURFACE ANALYSIS REPORT (SASAR)

Number: DI-IPSC-82250A
AMSC Number: 10218
DTIC Applicable: No
Preparing Activity: MDA
Applicable Forms: None

Approval Date: 20210211
Limitation: N/A
GIDEP Applicable: No
Project Number: IPSC-2021-002

Use/Relationship: The Software Attack Surface Analysis Report (SASAR) documents the results of the attack surface analysis activities. The attack surface of a software environment is the sum of the different points of attack vectors where unauthorized users enter data to, or extract data from, software an environment. Keeping the attack surface as small as possible is a key Software Assurance (SwA) objective. The SASAR involves the following:

a. Updating the Software Threat Assessment Report (STAR), DI-IPSC-82251A, with all attack surfaces enumerated and documented in the SASAR.
b. Identifying directly or by reference in the Software Development Plan (SDP), Firmware Development Plan (FDP), Program Protection Implementation Plan (PPIP), or equivalent documents, that design or modification of the software attack surface areas defined by the SASAR, require formal cybersecurity and software assurance review, assessment, and documented within the system test plan.
c. The SASAR is used as input to the risk assessments completed in the Software Vulnerability Assessment Report (SVAR), DI-IPSC-82252, and the Software Assurance Evaluation Report (SAER), DI-IPSC-82249.

This DID contains the format, content, and intended use information for the data deliverable resulting from the work task described in the contract. This DID can be used in conjunction with DI-IPSC-82251A; DI-IPSC-82252A; DI-IPSC-82249A; DI-ADMIN-81306; Program Protection Implementation Plan (PPIP); DI-IPSC-81427, Software Development Plan (SDP); and DI-SESS-82045, Firmware Development Plan (FDP). This DID supersedes DI-IPSC-82250.

Requirements:

1. Reference Documents.

The applicable issue of the documents cited herein, including their approval dates and dates of any applicable amendments, notices, and revisions, shall be as specified in the contract.

a. "DoD Developer's Guidebook for Software Assurance," Carnegie Mellon University, Software Engineering Institute (SEI), Federally Funded Research and Development Center (FFRDC). https://resources.sei.cmu.edu/library/asset-view.cfm?assetid=539177
b. "Program Manager's Guidebook for Software Assurance," Carnegie Mellon University, Software Engineering Institute (SEI), Federally Funded Research and

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:01Z
Check the source to verify that this is the current version before use.

Development Center (FFRDC). https://resources.sei.cmu.edu/library/asset-view.cfm?assetid=538771

c. "Software Assurance Evaluation Report (SAER)," DID Number DI-IPSC-82249, https://assist.dla.mil

d. "Software Vulnerability Assurance Report (SVAR)," DID Number DI-IPSC-82252, https://assist.dla.mil

e. "Software Threat Assessment Report (STAR)," DID Number DI-IPSC-82251, https://assist.dla.mil

f. Open Web Application Security Program (OWASP), Cheat Sheets, Attack Surface Analysis https://cheatsheetseries.owasp.org/cheatsheets/Attack_Surface_Analysis_Cheat_Sheet.html

g. "A Threat-Driven Approach to Cyber Security," © 2019 Lockheed Martin Corporation, https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM-White-Paper-Threat-Driven-Approach.pdf

2. Format.

The report shall be in contractor format unless tailored out in the Contract Data Requirements List (CDRL) (DD 1423).

3. Content.

This section shall be divided into paragraphs, as needed, to establish the context for the content described in later sections. The term "document" in this DID shall mean a collection of data regardless of its medium. The terms "section" and "paragraph" in this DID shall mean their equivalents in a digital format that fulfill the section or paragraph's requirements.

3.1 Reference Documents

This section shall list the number, title, revision, and date of all documents referenced in this report. This section shall also identify the source for all documents not available through normal Government stocking activities.

3.2 Document Management and Configuration Control

This section shall identify the version, release date, and other relevant management and configuration control information associated with the current version of the report. A change history, highlighting significant changes from version to version shall be included.

3.3 Table of Contents

This section shall index all sections, major paragraphs, subparagraphs and appendices with page numbers.

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:01Z
Check the source to verify that this is the current version before use.

3.4 Document Scope

This section shall be divided into paragraphs covering system and software or Computer Software Configuration Item (CSCI) identification, system overview and document overview.

3.4.1 System and Software or Computer Software Configuration Item (CSCI) Identification

This section shall contain a full identification of the system and the software or CSCI to which this document applies, including, as applicable, identification number(s), title(s), abbreviation(s), version number(s), and release number(s).

3.4.2 System Overview

This section shall briefly state the purpose of the system to which this report applies. It shall describe the general nature of the system and software or CSCI; summarize the history of system development, operation, and maintenance; identify the project sponsor, acquirer, user, developer, and support agencies; identify current and planned operating sites; and list other relevant documents.

3.4.3 Document Overview

This section shall summarize the purpose and contents of this report and shall describe any security or privacy considerations associated with its use.

3.5 Attack Surface Definition

This section shall define the attack surface of the software application, to include:

a. The applicable system, software, or CSCI boundaries (e.g., trust boundaries, accreditation boundaries, technical or environmental boundaries).
b. All paths for data and commands into and out of the application, (e.g., Application Programming Interfaces (API); Data-Flow Diagrams (DFD); Ports, Protocols, and Services (PP&S); data sources; trust levels formats; and integrity checks).
c. The code that protects these paths, including (as applicable) resource connection and authentication, authorization, activity logging, data validation, encoding and integrity checking.
d. All valuable data used in the application (e.g., secret keys; intellectual property; critical business data; Control Unclassified Information (CUI); classified data and data with special handling requirements, such as: NATO//RD//FRD//CNWDI//NOFORN, and Personally Identifiable Information (PII)).
e. The code that protects this critical valuable data (e.g., encryption, checksums, access auditing, and data integrity and operational security controls).

3.6 Attack Surface Identification and Mapping

This section shall identify each attack surface and map applicable threats from DI-IPSC-82251 against the attack surface. Include mapping out all the devices, paths and networks necessary to comprehensively visualize the enterprise system.

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:01Z
Check the source to verify that this is the current version before use.

3.7 Measure and Assess the Attack Surface

This section shall measure and assess the attack surface (e.g., identify the high-risk to low-risk areas). For each identified attack surface, document the following:

a. Assessed risk level (likelihood and impact).
b. Development cyber test cases that map to the attack surface and threat capability to test sufficiency of the code that protects these paths, as well as data protections used in the application.

3.8 Notes

This section shall contain any general information that aids in understanding this report (e.g., background information, glossary, rationale). This section shall include an alphabetical listing of all acronyms, abbreviations, and their meanings as used in this report and a list of any terms and definitions needed to understand this report.

3.9 Appendices

Appendices shall provide information published separately for convenience in document maintenance (e.g., charts, classified data, etc.), as necessary. As applicable, each appendix shall be referenced in the report where the data would normally have been provided. Appendices shall be lettered alphabetically (A, B, etc.).

3.9.1 Open Architecture Conflicts

Document where open architecture requirements conflict in an appendix to this report, including proposed resolution thereof.

END OF DI-IPSC-82250A

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:01Z
Check the source to verify that this is the current version before use.